

IA appliquée à la sécurité informatique

Diapositives complètes — Dr. Zakaria Sawadogo, École Polytechnique de Ouagadougou

Chapitre 1 — Introduction : IA et cybersécurité, panorama

IA appliquée à la sécurité informatique

DR. ZAKARIA SAWADO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Pourquoi l'IA en cybersécurité ?

Les volumes de données à surveiller (journaux, flux réseau, alertes) ont dépassé depuis longtemps la capacité d'analyse manuelle humaine. L'IA et le machine learning (ML) permettent d'automatiser la détection de schémas (patterns) suspects, de traiter des volumes massifs en temps quasi réel, et de détecter des menaces nouvelles (« zero-day ») que des règles de détection statiques (signatures) ne couvrent pas encore.

2. Deux faces d'une même discipline

- **IA défensive** : détection d'intrusions, de malwares, de phishing, priorisation d'alertes, automatisation de la réponse à incident (SOAR).
- **IA comme surface d'attaque** : les systèmes d'IA eux-mêmes deviennent des cibles (empoisonnement de données d'entraînement, attaques adversariales, extraction de modèle).
- **IA offensive** : usage de l'IA par les attaquants (génération de contenus de phishing convaincants, automatisation de la reconnaissance, génération de code malveillant).

Ce module couvre les trois dimensions, avec un accent particulier sur la défense (chapitres 3 à 5) puis sur la sécurité de l'IA elle-même (chapitre 6).

3. Cas d'usage défensifs courants

Cas d'usage	Type de tâche ML	Exemple
Détection d'intrusions réseau	classification supervisée / détection d'anomalies	identifier un trafic réseau anormal
Détection de malwares	classification supervisée	classer un fichier binaire comme sain/malveillant
Détection de phishing	classification de texte (NLP)	analyser le contenu d'un e-mail ou d'une URL
Analyse comportementale des utilisateurs (UEBA)	détection d'anomalies	repérer un compte utilisateur au comportement inhabituel
Priorisation d'alertes SOC	classification / scoring	réduire la fatigue d'alerte des analystes

4. Limites et illusions à éviter

- **Le ML n'élimine pas le besoin d'expertise humaine** : un modèle mal conçu ou mal évalué produit des faux positifs (fatigue d'alerte) ou des faux négatifs (menaces non détectées) coûteux.
- **Les données d'entraînement conditionnent tout** : un modèle entraîné sur un contexte donné (réseau, période) généralise mal à un contexte différent (concept drift).
- **Explicabilité** : un modèle « boîte noire » (ex. réseau de neurones profond) est difficile à auditer et à justifier auprès d'un analyste ou d'un régulateur — un critère important dans le choix du modèle selon le contexte d'usage.
- **L'IA n'est pas une solution miracle contre un attaquant déterminé** : un attaquant conscient qu'un système de détection utilise du ML peut chercher spécifiquement à le contourner (chapitre 6).

5. Articulation avec les autres modules du programme

Ce module s'appuie sur les notions de trafic réseau et de vulnérabilités vues en *Audit organisation et technique*, et prépare une lecture critique des outils de sécurité modernes (EDR, XDR, SIEM) qui intègrent aujourd'hui massivement des composants de ML.

| À retenir

- L'IA en cybersécurité recouvre trois dimensions : défense, sécurité de l'IA elle-même, et usage offensif par les attaquants.
- Le ML complète mais ne remplace pas l'expertise humaine et les approches par signatures/règles.
- La qualité et la représentativité des données d'entraînement sont le facteur déterminant de la performance réelle d'un système de détection basé ML.

Chapitre 2 — Rappels de machine learning

IA appliquée à la sécurité informatique

DR. ZAKARIA SAWADO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Apprentissage supervisé, non supervisé, par renforcement

Type	Principe	Exemple en sécurité
Supervisé	apprend à partir d'exemples étiquetés (entrée, sortie attendue)	classifier un fichier comme malware/sain à partir d'exemples déjà étiquetés
Non supervisé	découvre une structure dans des données non étiquetées	regrouper des connexions réseau similaires, détecter des anomalies
Par renforcement	un agent apprend par essai-erreur en maximisant une récompense	automatisation de la réponse à incident (usage encore émergent)

2. Classification vs régression

- **Classification** : prédire une catégorie (ex. « malveillant » / « bénin »).
- **Régression** : prédire une valeur continue (ex. score de risque entre 0 et 100).

La plupart des cas d'usage en détection de sécurité relèvent de la classification (binaire ou multi-classe).

3. Cycle de vie d'un projet de machine learning

1. **Collecte et préparation des données** : nettoyage, gestion des valeurs manquantes, normalisation.
2. **Ingénierie des caractéristiques (feature engineering)** : transformer des données brutes (paquets réseau, texte) en variables numériques exploitables par un modèle.
3. **Séparation des données** : ensemble d'entraînement, de validation, de test — pour éviter le surapprentissage (*overfitting*).
4. **Entraînement du modèle**.
5. **Évaluation** sur des données jamais vues par le modèle.
6. **Déploiement et supervision continue** (un modèle en production doit être réévalué régulièrement : concept drift).

4. Quelques algorithmes classiques

Algorithme	Type	Caractéristique
Régression logistique	supervisé, classification	simple, interprétable, bonne base de référence
Arbre de décision / Forêt aléatoire (Random Forest)	supervisé, classification/régression	robuste, gère bien les données hétérogènes, relativement interprétable
SVM (Support Vector Machine)	supervisé, classification	efficace en haute dimension
K-means	non supervisé, clustering	regroupe des observations similaires
Isolation Forest	non supervisé, détection d'anomalies	isole les observations atypiques efficacement, utilisé en TP2
Réseaux de neurones / Deep Learning	supervisé ou non supervisé	performant sur données complexes (texte, image, séquences) mais moins interprétable

5. Métriques d'évaluation, essentielles en sécurité

Pour une classification binaire, la matrice de confusion distingue :

	Prédit positif	Prédit négatif
Réel positif	Vrai Positif (VP)	Faux Négatif (FN)
Réel négatif	Faux Positif (FP)	Vrai Négatif (VN)

- **Précision** = $VP / (VP + FP)$: parmi les alertes levées, quelle proportion est réellement une menace ?
- **Rappel (recall)** = $VP / (VP + FN)$: parmi les menaces réelles, quelle proportion a été détectée ?
- **F1-score** : moyenne harmonique de précision et rappel.
- **Taux de faux positifs** = $FP / (FP + VN)$: critique en sécurité, car un taux élevé provoque la « fatigue d'alerte » des analystes, qui finissent par ignorer les alertes.

En sécurité, la simple exactitude globale (accuracy) est souvent trompeuse : sur un jeu de données très déséquilibré (ex. 0,1 % de trafic réellement malveillant), un modèle qui prédit toujours « bénin » atteint 99,9 % d'exactitude tout en étant totalement inutile. D'où l'importance du rappel et de la précision, en particulier sur la classe minoritaire (l'attaque).

6. Surapprentissage et sous-apprentissage

- **Surapprentissage (overfitting)** : le modèle « apprend par cœur » les données d'entraînement et généralise mal à de nouvelles données.
- **Sous-apprentissage (underfitting)** : le modèle est trop simple pour capturer la structure des données.

La validation croisée (cross-validation) et un ensemble de test totalement indépendant permettent de détecter ces situations avant tout déploiement.

À retenir

- Le choix entre supervisé/non supervisé dépend de la disponibilité de données étiquetées, souvent rare en sécurité pour les attaques nouvelles.
- Précision, rappel et F1-score, pas la seule exactitude, sont les métriques pertinentes pour évaluer un modèle de détection en contexte déséquilibré.
- Le cycle de vie complet (données → features → entraînement → évaluation → supervision continue) doit être maîtrisé, pas seulement l'entraînement du modèle.

Chapitre 3 — Détection d'anomalies et d'intrusions par ML

IA appliquée à la sécurité informatique

DR. ZAKARIA SAWADO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Détection par signatures vs détection par anomalies

Approche	Principe	Avantage	Limite
Signatures	comparaison à des motifs d'attaques connues	très faible taux de faux positifs sur les menaces connues	ne détecte pas les attaques inédites
Anomalies (ML)	apprentissage du comportement « normal », alerte sur tout écart significatif	peut détecter des menaces nouvelles (zero-day)	taux de faux positifs souvent plus élevé, nécessite une phase d'apprentissage du « normal »

En pratique, les IDS/IPS (systèmes de détection/prévention d'intrusion) modernes combinent les deux approches.

2. Sources de données pour un IDS basé ML

- **Trafic réseau** : caractéristiques dérivées des flux (NetFlow) : durée de connexion, protocole, nombre d'octets échangés, nombre de paquets, taux d'erreur.
- **Journaux systèmes/applicatifs** : séquences d'événements, fréquence des connexions échouées.
- **Comportement utilisateur (UEBA)** : horaires de connexion habituels, ressources accédées, volume de données téléchargées.

3. Ingénierie des caractéristiques pour le trafic réseau

Exemple de caractéristiques dérivées classiques (utilisées dans le jeu de données NSL-KDD, réutilisé en TP1) :

- durée de la connexion ;
- type de protocole (TCP, UDP, ICMP) ;
- service ciblé (HTTP, FTP, SSH...) ;
- nombre d'octets source → destination et destination → source ;
- nombre de tentatives de connexion échouées récentes vers le même hôte ;
- taux de connexions vers un même service dans une fenêtre temporelle glissante.

Le passage de paquets réseau bruts à ce type de caractéristiques agrégées est une étape déterminante : un modèle ne peut être meilleur que les caractéristiques qui lui sont fournies.

4. Approches non supervisées de détection d'anomalies

- **Clustering (K-means, DBSCAN)** : les points isolés ou dans de petits clusters sont considérés suspects.
- **Isolation Forest** : construit des arbres aléatoires ; une observation atypique nécessite en moyenne moins de séparations pour être isolée, ce qui produit un score d'anomalie.
- **Autoencodeurs (réseaux de neurones)** : le modèle apprend à reconstruire les données normales ; une erreur de reconstruction élevée sur une nouvelle observation signale une anomalie potentielle.

5. Approches supervisées

Lorsque des données étiquetées (trafic normal vs attaques connues, ex. jeux NSL-KDD ou CICIDS) sont disponibles, une classification supervisée (Random Forest, SVM, réseaux de neurones) obtient généralement de meilleures performances qu'une approche purement non supervisée, mais reste limitée aux catégories d'attaques représentées dans les données d'entraînement.

6. Défis pratiques du déploiement en production

- **Déséquilibre des classes** : les attaques représentent une infime fraction du trafic total ; des techniques de rééquilibrage (sur-échantillonnage, sous-échantillonnage, SMOTE) ou des métriques adaptées (chapitre 2) sont nécessaires.
- **Dérive conceptuelle (concept drift)** : le trafic « normal » évolue dans le temps (nouveaux usages, nouvelles applications), un modèle doit être réentraîné périodiquement.
- **Volumétrie et latence** : un IDS doit souvent traiter des flux en temps réel, ce qui contraint le choix et la complexité du modèle.
- **Intégration avec le SOC** : les alertes générées doivent être exploitables par des analystes humains (contexte, explicabilité, priorisation).

À retenir

- Les systèmes de détection combinent en général signatures (précis mais limités aux menaces connues) et ML par anomalies (couvre potentiellement les menaces nouvelles, au prix de plus de faux positifs).
- La qualité des caractéristiques extraites du trafic brut conditionne fortement la performance du modèle.
- Le déséquilibre des classes et la dérive conceptuelle sont deux défis pratiques majeurs, souvent sous-estimés lors du passage du prototype à la production.

Chapitre 4 — Détection de malwares par machine learning

IA appliquée à la sécurité informatique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Limites de la détection par signatures pour les malwares

Les antivirus traditionnels reposent largement sur des signatures (empreintes de fichiers malveillants connus). Cette approche est mise en échec par le **polymorphisme** (le malware modifie son code à chaque propagation tout en gardant le même comportement) et le **métamorphisme**, ainsi que par le volume considérable de nouvelles variantes produites quotidiennement, rendant la maintenance d'une base de signatures exhaustive impraticable.

2. Deux approches d'analyse pour l'extraction de caractéristiques

Approche	Principe	Avantage	Limite
Analyse statique	examen du fichier sans l'exécuter (structure du binaire, chaînes de caractères, imports de fonctions système, entropie)	rapide, sans risque d'exécution	contournable par obfuscation, chiffrement du code (packers)
Analyse dynamique	exécution du fichier dans un environnement contrôlé (sandbox) et observation du comportement (appels système, connexions réseau, modifications de fichiers/registre)	détecte le comportement réel, résiste mieux à l'obfuscation	plus lente, coûteuse en ressources, certains malwares détectent la sandbox et modifient leur comportement

3. Caractéristiques exploitées en analyse statique

- Métadonnées du fichier (taille, en-têtes, section PE pour les exécutables Windows).
- Entropie du fichier ou de ses sections (une entropie élevée peut indiquer un chiffrement/compression, fréquent dans les malwares packés).
- N-grammes d'octets ou d'instructions assembleur.
- Fonctions de l'API système importées (ex. appels réseau, manipulation de la mémoire, techniques d'injection de processus).

4. Caractéristiques exploitées en analyse dynamique (sandbox)

- Séquence d'appels système (syscalls) effectués.
- Connexions réseau initiées (domaines contactés, protocoles).
- Modifications du système de fichiers et de la base de registre.
- Techniques de persistance observées (création de tâches planifiées, clés de démarrage).

5. Modèles utilisés

- **Classification supervisée** (Random Forest, gradient boosting, réseaux de neurones) sur des caractéristiques extraites statiquement et/ou dynamiquement : approche la plus répandue dans les solutions commerciales (EDR de nouvelle génération).
- **Modèles de séquence** (RNN, Transformers) pour modéliser directement la séquence d'appels système observée en sandbox, capturant mieux les dépendances temporelles du comportement.
- **Clustering** de familles de malwares pour regrouper des variantes proches et prioriser l'analyse humaine.

6. Techniques d'évasion contre les détecteurs ML

- **Obfuscation et packing** : rend l'analyse statique moins efficace en masquant les caractéristiques exploitables.
- **Détection d'environnement virtualisé/sandbox** : le malware modifie son comportement (ou reste inactif) s'il détecte qu'il s'exécute dans un environnement d'analyse.
- **Exemples adversariaux** : modification minimale d'un binaire (ajout d'octets inoffensifs, réorganisation de sections) pour franchir la frontière de décision d'un modèle sans changer le comportement malveillant réel — approfondi au chapitre 6.

7. Limites et bonnes pratiques

Un détecteur ML de malwares doit être régulièrement réentraîné (nouvelles familles), évalué sur des échantillons réellement représentatifs (pas seulement des échantillons « faciles »), et combiné avec des mécanismes complémentaires (réputation de fichiers, analyse comportementale en production, threat intelligence) plutôt qu'utilisé comme unique ligne de défense.

À retenir

- L'analyse statique est rapide mais contournable par obfuscation ; l'analyse dynamique observe le comportement réel mais coûte plus cher et peut être détectée par le malware.
- Les modèles de classification supervisée sur caractéristiques extraites sont l'approche la plus répandue en pratique.
- Les techniques d'évasion (obfuscation, détection de sandbox, exemples adversariaux) rappellent qu'un détecteur ML n'est jamais une solution unique et définitive.

Chapitre 5 — NLP appliqué à la sécurité (phishing, analyse de logs)

IA appliquée à la sécurité informatique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Le traitement automatique du langage naturel (NLP) en cybersécurité

Le NLP permet d'analyser automatiquement des contenus textuels : e-mails, messages, URL, journaux d'événements, rapports de threat intelligence. En sécurité, ses deux applications les plus répandues sont la détection de phishing et l'analyse assistée de journaux volumineux.

2. Représentation du texte pour le machine learning

Un modèle ML ne manipule pas directement du texte : il faut le transformer en représentation numérique.

Méthode	Principe	Caractéristique
Bag-of-words / TF-IDF	compte (pondéré) l'occurrence des mots, sans tenir compte de l'ordre	simple, efficace pour des tâches de classification classiques
N-grammes de caractères	séquences de n caractères consécutifs	robuste aux fautes d'orthographe volontaires (technique d'évasion courante en phishing)
Word embeddings (Word2Vec, GloVe)	représentation vectorielle dense capturant des relations sémantiques entre mots	capture le sens, plus coûteux à entraîner
Modèles de langage pré-entraînés (Transformers, type BERT)	représentation contextuelle, état de l'art actuel	performance élevée, coût de calcul plus important

3. Détection de phishing par e-mail

Caractéristiques exploitées, combinant NLP et méta-données :

- contenu textuel du message (urgence, demande d'action, fautes, incitation au clic) ;
- caractéristiques de l'expéditeur (domaine récemment enregistré, usurpation d'affichage — *display name spoofing*) ;
- caractéristiques des URL contenues (longueur, présence de caractères trompeurs, similarité avec un domaine légitime — *typosquatting*) ;
- en-têtes techniques du message (résultats SPF/DKIM/DMARC, incohérences de routage).

Une approche efficace combine généralement un modèle NLP sur le contenu du message et des règles/caractéristiques dédiées à l'analyse des URL et des en-têtes, plutôt qu'un seul modèle « texte brut ».

4. Détection d'URL malveillantes

Approche fréquente : classification supervisée à partir de caractéristiques lexicales de l'URL elle-même (longueur, nombre de sous-domaines, présence de caractères spéciaux, entropie), sans nécessairement visiter la page cible — utile pour un filtrage rapide en amont.

5. Analyse de journaux (log analysis) assistée par NLP

Les journaux systèmes et applicatifs peuvent être traités comme du texte semi-structuré :

- **Regroupement de motifs (log clustering / log parsing)** : regrouper des lignes de log similaires en « templates » (ex. outils comme `Drain`), pour réduire des millions de lignes à quelques centaines de motifs analysables.
- **Détection d'anomalies séquentielles** : modéliser la séquence normale d'événements (via un modèle de séquence) et détecter les déviations, potentiellement révélatrices d'un comportement d'attaque (ex. séquence anormale de commandes après une compromission).
- **Résumé automatique** : synthétiser de grands volumes d'alertes pour un analyste SOC, en s'appuyant de plus en plus sur des modèles de langage génératifs (avec vigilance sur la fiabilité de leurs sorties, cf. chapitre 6).

6. Limites spécifiques au NLP en sécurité

- Les attaquants adaptent activement leur texte pour éviter la détection (fautes volontaires, homoglyphes, texte caché dans des images) — un jeu du chat et de la souris comparable à celui vu pour les malwares.
- Un modèle NLP entraîné sur une langue ou un contexte culturel donné généralise mal à d'autres langues ou contextes.
- Le contenu généré automatiquement par des modèles de langage (utilisé de façon offensive par des attaquants pour rédiger des messages de phishing très convaincants et sans fautes, y compris en plusieurs langues) réduit l'efficacité des indicateurs textuels classiques (fautes d'orthographe, formulations maladroites) longtemps utilisés pour repérer le phishing.

À retenir

- Le NLP transforme du texte en représentation numérique exploitable par un modèle (TF-IDF, embeddings, Transformers), avec un compromis performance/coût de calcul.
- La détection de phishing combine efficacement analyse du contenu textuel et caractéristiques techniques (URL, en-têtes, authentification du domaine).
- L'essor des modèles de langage génératifs facilite la production de contenus de phishing convaincants, ce qui affaiblit les indicateurs textuels traditionnels et pousse vers des défenses combinant plusieurs signaux.

Chapitre 6 — Sécurité de l'IA : attaques adversariales et IA offensive

IA appliquée à la sécurité informatique

DR. ZAKARIA SAWADO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. L'IA comme nouvelle surface d'attaque

À mesure que des systèmes d'IA sont déployés dans des fonctions sensibles (détection de fraude, contrôle d'accès biométrique, filtrage de contenu, systèmes autonomes), ils deviennent eux-mêmes des cibles. Le référentiel **OWASP Machine Learning Security Top 10** et le cadre **MITRE ATLAS** recensent ces menaces spécifiques.

2. Attaques adversariales (evasion attacks)

Principe : modifier légèrement une entrée, de façon souvent imperceptible pour un humain, pour tromper un modèle et lui faire produire une prédiction erronée, sans modifier le comportement réel de l'objet analysé.

- **Sur des images** : ajouter un bruit calculé, invisible à l'œil nu, qui fait classer une image de panneau stop comme un panneau de limitation de vitesse par un modèle de vision.
- **Sur des malwares** : ajouter des octets inoffensifs à un binaire malveillant pour franchir la frontière de décision d'un classifieur, sans changer le comportement malveillant réel (évoqué au chapitre 4).
- **Sur du texte (phishing, spam)** : introduire des variations orthographiques, des caractères invisibles ou des synonymes pour échapper à un filtre NLP tout en restant compréhensible par un humain.

Modèles d'attaque

Modèle	Connaissance de l'attaquant
Boîte blanche (white-box)	accès complet au modèle (architecture, paramètres) — permet de calculer des perturbations optimales
Boîte noire (black-box)	accès uniquement aux prédictions du modèle (requêtes successives) — attaques par substitution (entraîner un modèle de substitution pour approximer les frontières de décision)

3. Empoisonnement de données (data poisoning)

Attaque visant la **phase d'entraînement** plutôt que l'inférence : un attaquant capable d'injecter des données malveillantes dans le jeu d'entraînement (ex. un système qui se ré-entraîne en continu sur des données utilisateurs) peut dégrader la performance générale du modèle ou y insérer une **porte dérobée (backdoor)** : le modèle se comporte normalement sauf en présence d'un déclencheur spécifique connu de l'attaquant, qui provoque alors une prédiction choisie.

4. Extraction et inversion de modèle

- **Extraction de modèle (model extraction)** : reconstruire une approximation d'un modèle propriétaire à partir de requêtes successives à son API, permettant de le voler ou de préparer une attaque adversariale en boîte blanche sur la copie.
- **Inversion de modèle / attaque par appartenance (membership inference)** : déterminer si une donnée spécifique a été utilisée dans l'entraînement d'un modèle, ou reconstruire partiellement des données d'entraînement sensibles — un enjeu direct de confidentialité (RGPD) lorsque le modèle a été entraîné sur des données personnelles.

5. IA offensive : usage par les attaquants

- Génération automatisée de contenus de phishing personnalisés et sans fautes, à grande échelle.
- Assistance à l'écriture de code malveillant ou à l'automatisation de tâches de reconnaissance.
- Génération de deepfakes (voix, image, vidéo) utilisés dans des fraudes ciblées (ex. usurpation de la voix d'un dirigeant pour autoriser un virement frauduleux).
- Automatisation partielle de certaines phases de reconnaissance ou de rédaction de rapports par des attaquants.

6. Contre-mesures et bonnes pratiques

Menace	Contre-mesure
Attaques adversariales	entraînement adversarial (inclure des exemples adversariaux dans l'entraînement), détection de perturbations anormales, limitation du taux de requêtes à une API de modèle
Empoisonnement de données	validation et traçabilité des sources de données d'entraînement, détection d'anomalies dans les données avant réentraînement
Extraction/inversion de modèle	limitation et surveillance des requêtes API, techniques de confidentialité différentielle
IA offensive (phishing, deepfakes)	sensibilisation renforcée, vérification hors bande des demandes sensibles (procédures « callback » avant tout virement), défenses multi-sigaux ne reposant pas uniquement sur des indices textuels

| À retenir

- Les systèmes d'IA sont vulnérables à des classes d'attaques spécifiques (adversariales, empoisonnement, extraction) distinctes des vulnérabilités logicielles classiques.
- Les modèles de connaissance de l'attaquant (boîte blanche/noire) déterminent la faisabilité pratique de ces attaques.
- L'IA offensive (contenus de phishing, deepfakes) accroît la sophistication des attaques d'ingénierie sociale et impose des contre-mesures organisationnelles autant que techniques.